Altoro Mutual Bank Vulnerabilities Assessment Testing Report

Prepared by:

SAMSUZZOHA SHAMIM
Software Security Engineer | Analyst

Date: 10-05-2026

Professional Summary

Dedicated Software Security Engineer with over 2 years of hands-on experience in Web and Mobile Application Security Testing, Vulnerability Assessment, and Penetration Testing (VAPT). Specialized in identifying, analyzing, and validating security vulnerabilities across modern applications using both automated and manual testing methodologies. Strong expertise in conducting security assessments based on OWASP Top 10 standards, industry best practices, and risk-based testing approaches to strengthen overall application security posture.

Experienced in performing comprehensive security testing for web applications, mobile applications, and APIs, including authentication and authorization testing, session management analysis, input validation testing, business logic testing, security misconfiguration assessment, and API security validation. Skilled in discovering vulnerabilities such as Cross-Site Scripting (XSS), SQL Injection, IDOR, Authentication Bypass, Security Misconfigurations, Sensitive Data Exposure, CSRF, SSRF, and other application-layer security flaws. Proficient in using industry-standard security tools including Burp Suite, OWASP ZAP, and various reconnaissance and testing utilities for effective vulnerability identification and validation.

Strong experience in preparing professional security assessment reports with detailed proof-of-concept findings, risk ratings, impact analysis, and remediation recommendations to support secure development practices. Capable of communicating technical vulnerabilities clearly to development and engineering teams while assisting in vulnerability remediation and retesting activities to ensure effective issue resolution.

Additionally, bringing more than 4 years of experience in Software Quality Assurance (SQA) and software testing, which provides a strong foundation in application behavior analysis, test planning, defect identification, and overall software quality processes. This combined background in security testing and quality assurance enables a deeper understanding of application workflows, functionality, and risk areas, contributing to more effective and thorough security assessments.

Passionate about application security, ethical hacking, and continuous improvement in cybersecurity practices. Focused on helping organizations build secure, reliable, and resilient applications through proactive security testing and risk-driven assessment methodologies.

Table of Contents

Contents

Table of Contents 3

1 Web Application Vulnerability Assessment 4

1.1 Executive Summary 4

1.2 Background 4

1.3 Objectives 4

1.4 Scope of Assessment 5

1.5 Out of Scope 5

1.6 Identified Vulnerabilities 6

1.7 Used Tools 6

1.8 Summary of the Vulnerabilities Assessment Testing 7

2 Vulnerabilities Details 9

2.1 SQL Injection 9

2.2 Cross-Site Scripting (XSS) 9

2.3 Brute Force Attacks 9

2.4 Cross-Site Request Forgery (CSRF) 10

2.5 No Rate Limit 10

2.6 Open Redirection (DOM-based) 10

2.7 Frameable Response (Potential Clickjacking) 10

2.8 Content Security Policy 11

2.9 Strict Transport Security (HSTS) Not Enforced 11

2.10 Cacheable HTTPS Response 11

2.11 DOM Data Manipulation (DOM-based) 12

2.12 Cross-domain Referrer Leakage 12

2.13 Path-relative Style Sheet Import 12

2.14 Referrer-dependent Response 12

2.15 Input Returned in Response (Reflected) 13

2.16 Sensitive Data Exposure (Email Address) 13

2.17 HTML Does Not Specify Charset 13

2.18 TLS Certificate Observation 13

3 Conclusion 14

1 Web Application Vulnerability Assessment

1.1 Executive Summary

The purpose of these Web Security Assessments was to identify and exploit exploitable vulnerabilities and insufficiently configured security controls to determine the likelihood that users with considerable, little, or no prior knowledge of the applications (e.g., informed, and uninformed insiders and outsiders) could exploit weaknesses in their applications as those cataloged in the OWASP Top 10, OWASP ASVS, SANS, NIST, OWASP testing guide and Penetration Testing Execution Standard.

The team leveraged tools to facilitate their work, however, the majority of the assessment involved automation & manual analysis. The details of the tools used in the testing are given in this report.

The results summarized in this document are based upon a collection of methodologies and tests interacting at a single point in time with technology that is continually changing and becoming ever more complex. Any projection to the future of the findings contained in this document is subject to the risk that they may no longer portray the system or environment in existence at that time because of change.

1.2 Background

This exercise aimed to perform Penetration Testing of the Applications in scope to determine if they were vulnerable to attacks and exploitation. The test consisted of automation & manual testing to detect and exploit vulnerabilities.

The assessment was conducted to identify and exploit the security vulnerabilities in the Application in scope and propose solutions for the project team to remediate the identified vulnerabilities to make the Application more secure.

The Security Assessment was performed by **Samsuzzoha Shamim** between **1st May 2026** to

10th May 2026.

1.3 Objectives

The objective of the tests performed was to:

- Finding the possible vulnerabilities and gaps in the web applications.
- Assess the gaps and vulnerabilities to determine the Risk associated.

This assessment report contains:

- **Technical details** of the vulnerabilities discovered with substantiation of the exploits.

1.4 Scope of Assessment

URLs

- https://demo.testfire.net

Accounts

User	Role	Password
jsmith	User	Demo1234

Environment Details

Application Name	Altoro Mutual Bank
Environment	Apache-Coyote/1.1
Accessibility	Internet
Authentication Method	Login
Frontend	Java/J2EE
Backend	Java/J2EE
Server	Apache-Coyote/1.1

1.5 Out of Scope

The following activities and applications were considered out of scope for this Engagement:

- Social Engineering
- Vulnerability Fixes
- Penetration Testing.

1.6 Identified Vulnerabilities

- SQL Injection
- Cross-Site Scripting (XSS)
- Brute Force Attacks
- Cross-Site Request Forgery (CSRF)
- No Rate Limit
- Open Redirection (DOM-based)
- Frameable Response (Potential Clickjacking)
- Content Security Policy Not Implemented
- Strict Transport Security (HSTS) Not Enforced
- Cacheable HTTPS Response
- DOM Data Manipulation (DOM-based)
- Cross-domain Referrer Leakage
- Path-relative Style Sheet Import
- Referrer-dependent Response
- Input Returned in Response (Reflected)
- Sensitive Data Exposure (Email Address)
- HTML Does Not Specify Charset
- TLS Certificate Observation

1.7 Used Tools

Commlink Info Tech ltd penetration testing team uses a combination of automation & manual testing and commercial/open-source tools as part of its penetration testing methodology. This is accompanied by custom scripts to ensure optimum results.

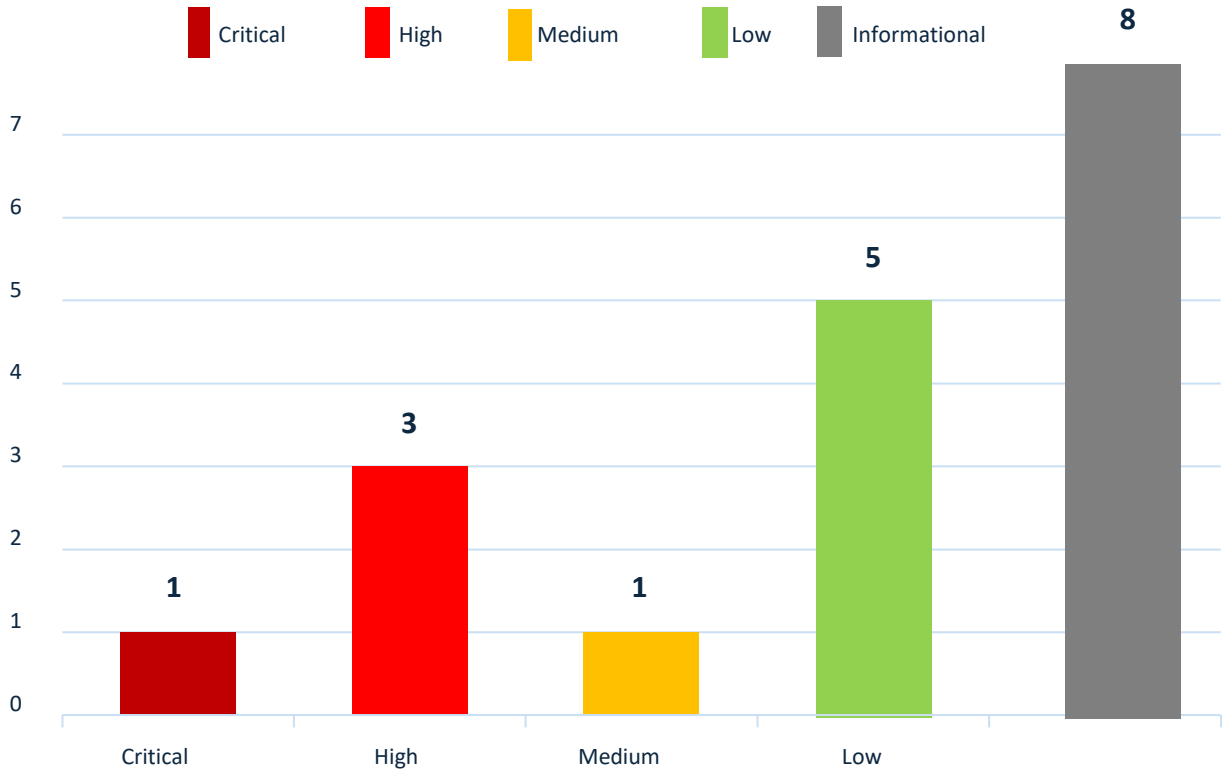
The following tools are used for the testing.

- Kali Linux
- Burp Suite Pro
- Acunetix
- OWASP Zap
- SQL Map
- jSQL
- Katana
- Dalfox
- Fuxploider
- Mozilla Firefox Plugins and Extensions
- Third Party Web Based Tools

1.8 Summary of the Vulnerabilities Assessment Testing

The Web Penetration Testing conducted for the target organization yielded important findings and insights. This summary provides an overview of the key results obtained during the assessment.

Sl. No.	Name	Findings	Risk Score	Severity
1	SQL Injection	Yes	9.1	Critical
2	XSS (Cross Site Scripting)	Yes	8.2	High
3	Brute Force Attacks	Yes	8.1	High
4	Cross-Site Request Forgery (CSRF)	Yes	8.0	High
5	No Rate Limit	Yes	6.5	Medium
6	Open Redirection (DOM-based)	Yes	4.3	Low
7	Frameable Response (Potential Clickjacking)	Yes	4.0	Low
8	Content Secure Policy	Yes	4.0	Low
9	Strict Transport Security (HSTS) Not Enforced	Yes	3.9	Low
11	Cacheable HTTPS Response	Yes	3.1	Informational
12	DOM Data Manipulation (DOM-based)	Yes	2.8	Informational
13	Cross-domain Referrer Leakage	Yes	2.6	Informational
14	Path-relative Style Sheet Import	Yes	2.3	Informational
15	Referrer-dependent Response	Yes	2.1	Informational
16	Input Returned in Response (Reflected)	Yes	2.0	Informational
17	Sensitive Data Exposure (Email Address)	Yes	1.8	Informational
18	HTML Does Not Specify Charset	Yes	1.0	Informational
19	TLS Certificate Observation	Yes	1.0	Informational



During the vulnerability assessment, a total of 19 security findings were identified within the application. The findings include 1 Critical, 3 High, 1 Medium, 5 Low, and 9 Informational vulnerabilities.

The identified vulnerabilities indicate the presence of security weaknesses related to input validation, authentication protection, security misconfigurations, and missing security controls. These issues may increase the risk of unauthorized access, client-side attacks, and information disclosure if not properly addressed.

It is recommended that the identified vulnerabilities be remediated based on their severity level to improve the overall security posture of the application.

2 Vulnerabilities Details

2.1 SQL Injection

SQL Injection is a web security vulnerability that allows attackers to interfere with the queries an application makes to its database. Improper validation of user-supplied input may allow malicious SQL queries to be executed.

Successful exploitation may lead to unauthorized access to sensitive information, authentication bypass, modification of database contents, or complete database compromise.

During the vulnerability assessment, it was identified that the application is vulnerable to SQL Injection attacks due to insufficient input validation. This issue has been classified as a Critical severity security risk.

2.2 Cross-Site Scripting (XSS)

Cross-Site Scripting (XSS) is a client-side injection vulnerability that occurs when untrusted input is included in web pages without proper sanitization or encoding.

Attackers may exploit this issue to execute malicious scripts within users' browsers, potentially leading to session hijacking, credential theft, or unauthorized actions.

During the vulnerability assessment, it was identified that the application is vulnerable to Cross-Site Scripting (XSS) attacks. This issue has been classified as a High severity security risk.

2.3 Brute Force Attacks

A brute force attack is a technique in which attackers attempt to gain unauthorized access by systematically trying multiple username and password combinations until valid credentials are identified.

Applications without sufficient authentication protection mechanisms are more susceptible to automated login attempts and credential guessing attacks.

During the vulnerability assessment, it was identified that the application is vulnerable to brute-force attacks due to insufficient protection controls. This issue has been classified as a High severity security risk.

2.4 Cross-Site Request Forgery (CSRF)

Cross-Site Request Forgery (CSRF) is a vulnerability that forces authenticated users to perform unintended actions on a web application without their knowledge or consent.
Attackers may exploit this issue by tricking users into submitting unauthorized requests, potentially leading to unauthorized account actions or data modification.
During the vulnerability assessment, it was identified that the application is vulnerable to Cross-Site Request Forgery (CSRF) attacks. This issue has been classified as a High severity security risk.

2.5 No Rate Limit

Rate limiting is a security mechanism used to control the number of requests sent to a specific endpoint within a defined period of time. Without proper rate limiting controls, attackers may send a large number of authentication requests in a short duration.
This weakness may allow attackers to perform automated password guessing or brute-force attacks against user accounts.
During the vulnerability assessment, it was observed that the application does not implement proper rate limiting mechanisms on the authentication functionality. This issue has been classified as a Medium severity security risk.

2.6 Open Redirection (DOM-based)

DOM-Based Open Redirect vulnerabilities occur when client-side scripts process user-controlled input and redirect users to external locations without proper validation.
Attackers may exploit this issue to redirect users to malicious or phishing websites, potentially leading to credential theft or social engineering attacks.
During the vulnerability assessment, it was identified that the application is vulnerable to DOM-Based Open Redirect attacks due to insufficient validation of user-controlled input. This issue has been classified as a Low severity security risk.

2.7 Frameable Response (Potential Clickjacking)

Frameable responses occur when the application can be loaded within frames or iframes from external domains due to missing anti-clickjacking protections.
Attackers may exploit this issue to trick users into interacting with hidden or malicious content through clickjacking attacks.

During the vulnerability assessment, it was observed that the application does not implement adequate clickjacking protection mechanisms. This issue has been classified as a Low severity security risk.

2.8 Content Security Policy

Content Security Policy (CSP) is a security mechanism that helps prevent client-side attacks such as Cross-Site Scripting (XSS) by restricting the sources from which content can be loaded.
When CSP is not implemented, the application becomes more exposed to malicious script injection and other client-side attacks.
During the vulnerability assessment, it was observed that the application does not implement Content Security Policy (CSP) headers. This issue has been classified as a Low severity security risk.

2.9 Strict Transport Security (HSTS) Not Enforced

HTTP Strict Transport Security (HSTS) is a security mechanism that forces browsers to communicate with web applications only over secure HTTPS connections.
Without HSTS implementation, attackers may attempt SSL stripping attacks and downgrade secure HTTPS communication to insecure HTTP connections. During the vulnerability assessment, it was observed that the application does not enforce HTTP Strict Transport Security (HSTS). This issue has been classified as a Low severity security risk.
During the vulnerability assessment, it was identified that the application is vulnerable to DOM-Based Open Redirect attacks due to insufficient validation of user-controlled input. This issue has been classified as a Low severity security risk.

2.10 Cacheable HTTPS Response

Cacheable HTTPS responses occur when sensitive or confidential information delivered over HTTPS can be stored in browser or intermediary caches.
Improper cache control mechanisms may expose sensitive information to unauthorized access from shared systems or cached storage.
During the vulnerability assessment, it was observed that the application returns cacheable HTTPS responses without appropriate cache control directives. This issue has been classified as an Informational security observation.

2.11 DOM Data Manipulation (DOM-based)

DOM-based data manipulation occurs when client-side scripts dynamically process or modify data within the Document Object Model (DOM) without sufficient validation or sanitization.

Improper handling of DOM data may increase the application's exposure to client-side attacks or unintended behavior.

During the vulnerability assessment, it was observed that the application performs DOM-based data manipulation through client-side scripts. This issue has been classified as an Informational security observation.

2.12 Cross-domain Referrer Leakage

Cross-domain referrer leakage occurs when sensitive URL information is unintentionally exposed to external domains through the HTTP Referrer header.
This issue may disclose internal application paths, session-related information, or sensitive parameters to third-party services.
During the vulnerability assessment, it was observed that the application exposes referrer information across external domains. This issue has been classified as an Informational security observation.

2.13 Path-relative Style Sheet Import

Path-relative stylesheet import vulnerabilities occur when stylesheets are referenced using relative paths that may be interpreted incorrectly by browsers.
Improper stylesheet imports may allow attackers to manipulate page rendering or inject unintended content under certain conditions.
During the vulnerability assessment, it was observed that the application uses path-relative stylesheet imports. This issue has been classified as an Informational security observation.

2.14 Referrer-dependent Response

Referrer-dependent responses occur when application behavior changes based on the value of the HTTP Referrer header.
Reliance on referrer headers for application functionality or security decisions may introduce security weaknesses because referrer values can be modified or omitted.

During the vulnerability assessment, it was observed that certain application responses depend on the HTTP Referrer header. This issue has been classified as an Informational security observation.

2.15 Input Returned in Response (Reflected)

Reflected input occurs when user-supplied data is returned in server responses without proper sanitization or encoding. Improper handling of reflected input may increase the risk of client-side injection attacks if additional protections are not implemented.
During the vulnerability assessment, it was observed that the application reflects user-supplied input within server responses. This issue has been classified as an Informational security observation.

2.16 Sensitive Data Exposure (Email Address)

Sensitive data exposure occurs when user-related information, such as email addresses, is unnecessarily disclosed within application responses or publicly accessible content. Exposure of sensitive information may assist attackers in phishing, social engineering, or user enumeration activities. During the vulnerability assessment, it was observed that the application exposes email address information within accessible content or responses. This issue has been classified as an Informational security observation.

2.17 HTML Does Not Specify Charset

Character encoding declarations help browsers correctly interpret and render webpage content. When HTML pages do not explicitly specify a charset, browsers may incorrectly interpret content, potentially leading to display inconsistencies or security-related parsing issues. During the vulnerability assessment, it was observed that the application HTML responses do not explicitly specify character encoding. This issue has been classified as an Informational security observation.

2.18 TLS Certificate Observation

TLS certificates are used to establish secure encrypted communication between clients and servers. During the vulnerability assessment, observations related to the TLS certificate configuration were identified. This observation has been classified as an Informational security observation.

3 Conclusion

The vulnerability assessment identified multiple security weaknesses across the application, including Critical, High, Medium, Low, and Informational findings. These findings highlight deficiencies in several key security areas such as input validation, authentication and session management, client-side security controls, transport layer protection, and overall application hardening.

Critical and High severity vulnerabilities, including issues such as SQL Injection, Cross-Site Scripting (XSS), Cross-Site Request Forgery (CSRF), and Brute Force weaknesses, may allow attackers to gain unauthorized access, manipulate application functionality, compromise user accounts, extract sensitive information, or perform malicious actions on behalf of legitimate users. These vulnerabilities pose a significant risk to the confidentiality, integrity, and availability of the application and associated data.

Additionally, Medium and Low severity issues such as missing rate limiting, clickjacking exposure, insecure transport configurations, and insufficient security headers indicate weaknesses in defensive security mechanisms and secure configuration practices. While these issues may not directly result in immediate compromise, they can increase the overall attack surface and may be leveraged in combination with other vulnerabilities to facilitate more advanced attacks.

Informational findings further indicate areas where security best practices and hardening measures can be improved. Although these issues may not present direct exploitation risks, addressing them will strengthen the application's overall security posture and improve resilience against future threats.

If left unresolved, the identified vulnerabilities could potentially lead to unauthorized access, sensitive data exposure, session hijacking, phishing attacks, account takeover, service abuse, and reputational damage. Therefore, immediate remediation is strongly recommended for Critical and High severity findings, followed by Medium and Low severity issues based on business impact and risk prioritization.

Overall, implementing the recommended remediation measures, including secure coding practices, robust input validation, proper authentication and authorization controls, security header enforcement, transport layer security improvements, and continuous security monitoring, will significantly enhance the security posture of the application, reduce exploitable attack surfaces, and improve the organization’s overall cyber resilience.